

IT-Security

Inhalte

- CIA-Triade und Grundbegriffe
- Kryptographie
- Identity & Access Management (IAM)
- Secure Software Development Lifecycle (SSDLC)
- Netzwerk- und IoT-Sicherheit
- ISMS - Information Security Management System
- Schwachstellen- und Patchmanagement
- KI-Sicherheit

Sicherheitsmaßnahmen im Unternehmen

Welche Maßnahmen (Prozesse, Regeln, Tools, Schulungen,...) werden in Ihrem Unternehmen ergriffen, um sich vor IT-Sicherheitsvorfällen zu schützen?

Denkanstoß: Welche Maßnahme verhindert einen Angriff, welche erkennt ihn und welche begrenzt den Schaden?

I LOVE YOU

Der Urknall der IT-Sicherheit

Steckbrief: VBS.LoveLetter.A

- **Datum:** 4. Mai 2000 (Ausgangspunkt: Philippinen)
- **Schaden & Ausmaß:** 5–10 Mrd. USD Schaden, ~10 % aller Rechner weltweit infiziert
- **Datei & UI-Falle:** LOVE-LETTER-FOR-YOU.TXT.vbs
(Endung .vbs standardmäßig ausgeblendet → wirkte wie .TXT)
- **System:** Windows Script Host (WSH) führte VBScript direkt ohne Sandbox aus

Die Köder-Mail



Funktionsweise des Wurms

- **1. Persistenz:**
 - Schreibt sich in den Registry-Autostart (`HKLM\...\Run`)
 - Kopiert sich als `MSKerne132.vbs` ins Windows-Systemverzeichnis
- **2. Schneeball-Verbreitung:**
 - Liest Outlook-Adressbuch (MAPI) aus und mailt sich an alle Kontakte
 - Führt weltweit zum Zusammenbruch von Mail-Servern
- **3. Zerstörung:**
 - Überschreibt Multimediadateien & Skripte (`.jpg` , `.js` , ...) mit eigenem Code
 - Versteckt `.mp3` -Dateien und ersetzt sie durch Wurm-Kopien

Täter & Rechtliches Nachspiel

- **Täter & Motiv:**
 - Onel de Guzman (24, Informatikstudent in Manila)
 - Ziel: Passwörter für kostenlosen Internetzugang abgreifen
- **Rechtsvakuum:**
 - Keine Cybercrime-Gesetze auf den Philippinen im Mai 2000
 - Weder klassischer Diebstahl noch Sachbeschädigung lag juristisch vor
- **Konsequenz:**
 - Anklage fallen gelassen (*Nulla poena sine lege*)
 - Beschleunigte Verabschiedung des *E-Commerce Act (RA 8792)*

Fazit & Lehren

- **Secure by Default:** Gefährliche Skripte dürfen nicht standardmäßig per Doppelklick starten
- **UI-Design ist Security:** Das Verstecken von Dateiendungen täuscht Anwender
- **Schnittstellensicherheit:** Unbeschränkter API-Zugriff (wie Outlook MAPI) ist fatal
- **Awareness:** Technik versagt, wenn Nutzer emotional manipuliert werden

Die CIA-Triade

Schutzziele & Sicherheitsbegriffe

Angreifer & Motivationen

Wer greift an?

- **Cyberkriminelle:** Finanzieller Profit, RaaS, Erpressung
- **Staaten (APTs):** Spionage, Geopolitik, Sabotage
- **Insider:** Sabotage, Datendiebstahl, Rache
- **Hacktivisten & Script Kiddies:** Protest, Aufmerksamkeit, Spieltrieb

Was sind die Ziele?

- **Finanzen:** Lösegeld (Ransomware), Konten
- **Know-how:** Wirtschaftsspionage, IP-Diebstahl
- **Disruption:** Produktionsausfall, DoS
- **Macht & Kontrolle:** Botnetze, Persistenz

Die CIA-Triade – Überblick

- **Confidentiality (Vertraulichkeit):** Schutz vor unbefugter Offenlegung (*Nur wer darf, liest mit*).
- **Integrity (Integrität):** Schutz vor unbefugter Modifikation (*Daten bleiben korrekt & unverfälscht*).
- **Availability (Verfügbarkeit):** Gewährleistung des Zugriffs (*Systeme stehen bei Bedarf bereit*).

C: Vertraulichkeit (Confidentiality)

- **Ziel:** Schutz sensibler Informationen vor unbefugtem Zugriff & Abfluss
- **Verschlüsselung in 3 Zuständen:**
 - *Data in Transit:* TLS, HTTPS, VPN (Schutz vor Abhören / Sniffing)
 - *Data at Rest:* AES-256, BitLocker (Schutz bei physischem Verlust / Diebstahl)
 - *Data in Use:* Secure Enclaves / Confidential Computing
- **Schutzmaßnahmen:**
 - **Least Privilege:** Zugriffsberechtigungen auf das absolute Minimum beschränken
 - **Authentifizierung & MFA:** Strenge Identitätsprüfung vor Freigabe
 - **Klassifizierung:** Öffentlich → Intern → Vertraulich → Streng vertraulich

I: Integrität (Integrity)

- **Ziel:** Korrektheit, Vollständigkeit und Unverfälschtheit von Daten & Systemen
- **Kryptographische Schutzmechanismen:**
 - **Kryptographische Hashes (z.B. SHA-256):** Eindeutige Prüfsummen gegen Manipulation
 - **Digitale Signaturen:** Hash + Asymmetrische Kryptographie (Beweis für Urheberschaft & Unversehrtheit)
 - **Code Signing & SBOM:** Schutz der Software-Lieferkette vor Schadcode
- **Systemische Kontrollen:**
 - Schreib-Zugriffskontrolle & strikte Eingabevalidierung (Input Validation)
 - Transaktionssicherheit (ACID) & revisionssicheres Logging

A: Verfügbarkeit (Availability)

- **Ziel:** Zeitgerechte und verlässliche Erreichbarkeit von Daten und Systemen
- **Wichtige Metriken:**
 - **SLA & Uptime:** 99,9 % (~8,7 h Downtime/Jahr) bis 99,999 % („Five Nines“)
 - **RPO & RTO:** Akzeptabler Datenverlust (RPO) und maximale Wiederanlaufzeit (RTO)
- **Maßnahmen zur Ausfallsicherheit:**
 - **Redundanz:** RAID, Load Balancer, Active/Active-Cluster, Geo-Redundanz
 - **3-2-1-Backup-Regel:** 3 Kopien, 2 verschiedene Medientypen, 1 Offsite (+ Unveränderbarkeit)
 - **DDoS-Abwehr:** Anycast-Netzwerke, Traffic Scrubbing, WAF & Rate Limiting

Der Balanceakt (CIA-Trade-Offs)

Die Schutzziele stehen häufig in natürlicher Konkurrenz:

- **C vs. A:**
Strikte Verschlüsselung & Isolation verlangsamt oder blockiert Zugriff im Notfall.
- **I vs. A:**
Aufwendige Prüfungen und Sperren belasten die Systemperformance.

Beispiel: Ein Notfallzugang verbessert die Verfügbarkeit, kann aber die Vertraulichkeit schwächen. Deshalb braucht er enge Rechte und Protokollierung.

Erweiterte Schutzziele

Moderne Sicherheitsmodelle ergänzen die CIA-Triade um zwei Kernaspekte:

- **Authentizität (Authenticity):**
 - *Echtheit der Identität und des Ursprungs*
 - „Bist du wirklich derjenige, für den du dich ausgibst?“ (MFA, Zertifikate)
- **Zurechenbarkeit / Nicht-Abstreitbarkeit (Non-Repudiation):**
 - *Beweiskraft von Handlungen*
 - Niemand kann eine getätigte Transaktion leugnen (Signaturen, Audit-Logs)

Einordnung: CIA beschreibt drei grundlegende Schutzziele; Authentizität und Zurechenbarkeit ergänzen das Modell, ersetzen es aber nicht.